

Access Is Authority

A practical guide to what AI can access, what it can do, and where you stay in control.

Prepared September 2026 · Educational and operational guidance; not a security or compliance certification.

RECOMMENDATION FIRST

Use AI where it creates real value, but do not give AI more authority than the job requires. Treat every connection as a grant of authority. Start with the least access necessary, keep a person in the loop for consequential actions, remove connections you no longer need, and review access regularly.

01 Why this matters now

For years, most business software behaved in a familiar way: a person opened an application, clicked a button, and the software performed a defined action. Generative AI changed the interface. Agentic AI changes the authority model. A modern AI system may be able to read data, choose among tools, take a series of actions, update systems, communicate externally, and continue working with limited supervision.

That does not mean businesses should avoid AI. It means the old habit of treating every integration as a harmless convenience is no longer adequate. A connection between an AI system and business software can create a chain of delegated authority. The practical question shifts from "Can this AI do the task?" to "What exactly are we allowing it to do, against which resources, and under whose authority?"

ACCESS IS AUTHORITY

The more an AI system can affect people, data, money, customers, or other systems, the more deliberately that authority should be granted and monitored.

02 The core principle: bounded authority

AUTOMATE WORK. DO NOT AUTOMATE ACCOUNTABILITY.

The goal is not to eliminate useful automation. It is to match a system's authority to the consequences of the job.

An authority ladder

LEVEL	WHAT IT MEANS	TYPICAL EXAMPLE
1 · Read	Can view information but cannot change it.	Summarize documents; search a knowledge base.
2 · Draft	Can prepare an action, but a person decides whether to use it.	Draft an email, proposal, or response.
3 · Write	Can change internal information.	Update a record, create a task, edit a file.
4 · Send / Publish	Can send information outside the organization or publish it.	Email a customer, post content.
5 · Delete / Spend	Can create difficult-to-reverse consequences.	Delete records, run code, make purchases.
6 · Authorize	Can approve actions, change permissions, create credentials, or invoke other systems.	Grant access, approve transactions, launch other automations.

As authority rises, so should scrutiny. Ask whether the action truly needs to be autonomous, whether it is logged, whether it can be reversed, and whether a person should approve it first.

03 The fast pass: four places to look first

If you only have twenty minutes, do not try to map every technical connection in the company. Start where a large share of everyday access is easiest to see. This fast pass is a starting point, not a certification that nothing else is connected.

- **Your Google or Microsoft account.** Look for areas labeled Third-party access, Connected apps, Authorized applications, or App permissions. These pages reveal services that were granted access when someone chose "Sign in with Google" or "Sign in with Microsoft."
- **Your browser.** Review installed extensions and remove anything you no longer use or recognize. Extensions can read page contents and act inside sessions where you are already signed in.
- **Your automation platforms.** Zapier, Make, Power Automate, n8n, or similar. Pay special attention to anything that can send messages, modify records, publish, or trigger other systems.
- **Your AI tools.** Review each product's own connected-app or connector settings. Look for access to email, calendars, files, CRM systems, code repositories, and other business data.

VOCABULARY, NOT BRITTLE MENU PATHS

Vendors rename menus. Look for terms such as Connected apps, Third-party access, Authorized applications, Integrations, Linked accounts, App permissions, or API access — usually under Security, Privacy, Account, or Admin settings. Menu names in this guide were current in September 2026; if one has moved, search that product's help for "connected apps" or "authorized applications."

WHAT THE FAST PASS WILL NOT CATCH

It may miss API keys and service accounts, integrations connected with a username and password instead of a Google or Microsoft sign-in, tools configured on an individual computer, vendor-side integrations enabled inside another product's admin console, and anything an employee set up under a personal account. If the consequences matter, do the thorough pass next.

WHAT YOU SHOULD HAVE WHEN YOU FINISH

A working inventory of the AI tools and connections you can identify — plus at least one thing you are going to review, reduce, or turn off. A list nobody acts on is just a list.

The 20-Minute AI Hygiene Check is the printable worksheet version of everything in this section.

04 The thorough pass

A basic AI hygiene review does not need to become a full security audit. The goal is to identify the places where AI or automation has meaningful access and understand what that access can do. Use the categories below when a quick review is not enough.

- AI assistants and copilots used by owners and employees.
- Connected apps, plugins, skills, and newer connection methods such as MCP, which lets AI tools call external tools and data sources.
- Email and calendar access.
- Cloud storage and shared drives.
- CRM, help desk, ticketing, and customer databases.
- Accounting, payments, purchasing, and expense systems.
- Website, CMS, social media, advertising, and publishing systems.
- Code repositories, developer tools, cloud infrastructure, and administrative consoles.
- Automation platforms such as Zapier, Make, n8n, Power Automate, or custom scripts.
- Browser extensions and desktop tools that can read page content or act inside logged-in sessions.
- API keys, dedicated service accounts, shared credentials, and other machine-to-machine access created for AI-related workflows.

PRIVACY PRINCIPLE

A hygiene review usually does not require passwords, API keys, customer data, or copies of confidential files. The purpose is to understand categories of access and authority. When a review can be completed without collecting sensitive data, that is usually the better design.

05 Seven questions to ask about every connection

1. What job is this connection supposed to perform?

If nobody can clearly explain why it exists, review or remove it.

2. What can it read?

Is the scope one folder, an entire drive, one mailbox, all mailboxes, selected records, or the whole account?

3. What can it change?

Write access is materially different from read access. Can it create, edit, move, or delete information?

4. Can it communicate externally?

Can it send email, message customers, post publicly, or publish content?

5. Can it create expensive or difficult-to-reverse consequences?

Look for deletion, payments, purchasing, code execution, production changes, credential creation, or chained automations.

6. Where is the human approval point?

For consequential actions, decide whether the AI recommends, drafts, or actually executes.

7. Can you see and stop what it is doing?

Know where activity is logged, who reviews it, and how access can be revoked quickly.

06 Practical safeguards

You do not need enterprise bureaucracy to improve your posture. A handful of simple habits provide substantial value without turning AI adoption into a compliance project.

- **Use least privilege.** Give the AI only the permissions necessary to perform the current task.
- **Prefer read before write.** If the value can be delivered with read-only access, do not grant write access merely because a setup wizard offers it.
- **Prefer draft before send.** A system that drafts a customer email is materially different from a system that can send it without review.
- **Keep humans in the loop for high-consequence actions.** Payments, deletion, publishing, production changes, and external communications deserve deliberate approval points.
- **Avoid owner or admin authority when a narrower account will do.** An automation usually should not operate with the full authority of the owner simply because that was easiest to configure.

- **Review old connections.** Experiments accumulate. Remove connectors, app permissions, extensions, service accounts, and automations no longer being used.
- **Know the kill switch.** Document how to disable the automation, revoke the connection, or rotate a key before a problem occurs.
- **Log consequential actions.** Where the platform supports it, retain activity history and make sure someone knows where to find it.
- **Separate experimentation from production.** Test new agents and automations somewhere lower-consequence before granting access to real customers or sensitive data.
- **Review on a schedule.** A simple quarterly review beats a perfect inventory created once and forgotten.

07 Red flags worth immediate review

- An AI tool or automation has administrator-level access simply because that was easiest to configure.
- An agent can send customer or employee communications without review, and the business never made that a deliberate policy decision.
- A tool can delete, publish, purchase, deploy code, or alter production systems without an approval step.
- No one remembers why an integration exists or who created it.
- A workflow acts under the owner's personal identity when narrower authority would be sufficient.
- Employees are independently adding AI tools, browser extensions, connectors, or MCP connections with no shared review process.
- The business cannot quickly explain how to revoke an AI tool's access.
- Important automated actions are not logged, or no one knows where those logs are.

08 What basic AI hygiene is not

AI hygiene is a practical management discipline. It is not a claim that a business is secure, compliant, or protected from all AI-related risk. Some situations require qualified cybersecurity, privacy, legal, or compliance professionals.

- Penetration testing or vulnerability assessment.
- Incident response after suspected compromise.
- Formal compliance certification or legal advice.
- Identity architecture or enterprise security engineering.
- Malware analysis, threat hunting, or forensic investigation.
- A guarantee that an AI model or agent will always behave as intended.

For organizations deploying high-authority agents, basic hygiene should be treated as a starting point rather than the end of the security conversation.

09 Our point of view

Rabbit River Systems is interested in useful AI, not maximal AI. A tool is not better simply because it has more autonomy, more integrations, or more access. The right design is the one that accomplishes the business objective with the least unnecessary authority and the clearest human accountability.

Before adding another connector, automation, or agent, ask:

- What problem are we solving?
- What information must the system see?
- What actions must it take?
- What should still require a person?
- What would happen if the system misunderstood the task?
- How quickly could we stop it?

OUR GUIDING PRINCIPLE

Do not give AI more authority than the job requires. Use AI to expand human capability while keeping consequential authority visible, bounded, and accountable.

If you'd rather talk it through

Most of this you can do yourself in an afternoon. If you get partway in and hit something you can't classify — a connector nobody recognizes, an automation with more reach than it needs, a question about whether a tool is worth the access it's asking for — that's a good twenty minutes.

rabbitriversystems.com/book

kevin@rabbitriversystems.com

The 20-minute check →

Rabbit River Systems · rabbitriversystems.com · Pacific Northwest · Veteran owned

Educational and operational guidance only; not legal, compliance, or cybersecurity certification advice.